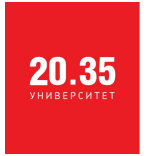
4.6. Python и ИБ эксплойты и уязвимости

4. Python в задачах информационной безопасности



В этом уроке

- Типы эксплойтов: веб (SQLi, XSS), сетевые (EternalBlue, Heartbleed), криптографические (перебор ключей).
- Реальные примеры: Log4Shell (CVE-2021-44228), XSS-атаки через некорректную обработку ввода.
- Инструменты: Metasploit, requests, scapy, PyCryptodome для анализа и тестирования уязвимостей.
- Методы защиты: валидация ввода, обновление ПО, использование CSP и HSTS.

Обнаружение SQL-инъекции

Цель: Написать скрипт, проверяющий уязвимость формы входа к SQL-инъекциям.

Инструменты: requests, BeautifulSoup.

Поиск XSS в параметрах URL

Цель: Проверить, отражается ли пользовательский ввод без фильтрации.

Инструменты: requests.

Сканирование открытых портов

Цель: Написать простой сканер портов.

Инструменты: socket

Проверка на переполнение буфера

Цель: Отправить длинную строку в уязвимое приложение.

Инструменты: subprocess

Анализ HTTP-заголовков на уязвимости

Цель: Проверить заголовки сервера на наличие опасных параметров.

Инструменты: requests.

Парсинг CVE из базы NVD

Цель: Получить данные об уязвимости через API NVD.

Инструменты: requests, json.

Скринкаст

Итоги урока

- Научились распознавать эксплойты и анализировать HTTP-заголовки на уязвимости (например, отсутствие CSP).
- Освоили применение инструментов (requests, scapy) для тестирования безопасности.
- Поняли, как защищать системы: валидация данных, патчи, настройка заголовков безопасности.
- Применили знания для автоматизации анализа уязвимостей (например, проверка заголовков сервера).